

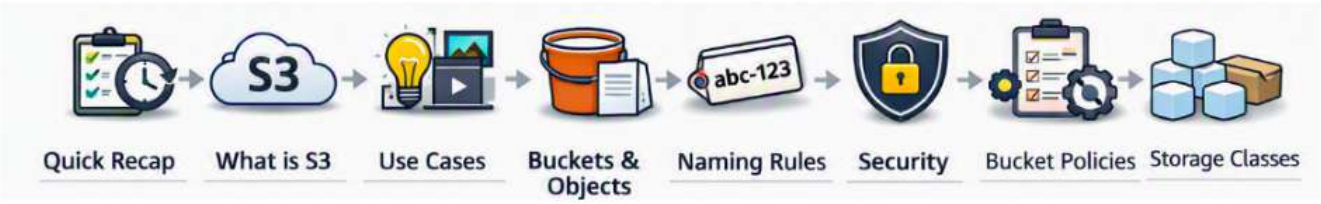
AWS Cloud Foundational Course

Day 3: Amazon S3 - Storage Fundamentals

Today's Learning Objectives

TekBay ACADEMY

- **By the end of this session, you will be able to:**
  - Explain what Amazon S3 is and how it works
  - Describe common real-world use cases for S3
  - Understand S3 buckets, objects, and naming rules
  - Explain the difference between user-based and resource-based security
  - Describe what a bucket policy is and what it controls
  - Compare the different S3 storage classes and know when to use each
- **Session Roadmap:**



Tip: *S3 is one of the most heavily tested services on the AWS exams - today's session is worth extra attention.*

Quick Recap - Day 2

- **Before we move on, let's recap what we covered yesterday:**

  - The AWS Well-Architected Framework is built on 6 pillars covering operations, security, reliability, performance, cost, and sustainability
  - IAM controls who can access your AWS account and what they're allowed to do
  - The Shared Responsibility Model splits security duties between AWS and the customer
  - IAM Users, Groups, and Roles are the building blocks of access management
  - IAM Policies use Effect, Action, and Resource to allow or deny permissions

Tip: *Today's topic, S3 security, builds directly on the IAM concepts from Day 2.*

What is Amazon S3?

- **Definition:**
  - Amazon S3 (Simple Storage Service) is AWS's object storage service - one of the most widely used services in all of AWS
  - It stores data as "objects" inside containers called "buckets"

- **Key facts:**
  - Bucket names must be globally unique across all AWS accounts
  - A single object can be up to **50 TB (recent change from 5 TB)** in size
  - S3 offers unlimited scalability - there's no limit on how much you can store
  - S3 offers multiple storage classes to balance cost and access speed

Tip: *Think of a bucket like a top-level folder, and objects like the files inside it.*

Amazon S3 Use Cases

TekBay ACADEMY



Tip: *If a company stores files "in the cloud," there's a good chance S3 is involved somewhere.*

S3 Buckets & Objects

TekBay ACADEMY

- **S3 Bucket:**
  - A container that holds your objects (files), created inside a specific AWS Region

- **S3 Object:**
  - Every object is identified by a Key, which represents its full path

    Example: s3://my-bucket/my-folder/my-file.txt
  - Objects can include metadata, tags, and (if enabled) a version ID





S3 Bucket with Objects

- **Uploading large files:**
  - Files larger than 5GB must use "multi-part upload," which splits the file into smaller parts

Tip: *The "key" is just the file's full path inside the bucket - including any folders.*

S3 Bucket Naming Rules



- **Every bucket name must follow these rules:**
    i. Only lowercase letters and numbers are allowed
    ii. No uppercase letters or underscores
    iii. Must be between 3 and 63 characters long
    iv. Cannot be formatted as an IP address
    v. Must start with a lowercase letter or number
    vi. Cannot begin with the prefix "xn--"
    vii. Cannot end with the suffix "-s3alias"

    Example: s3://adex-bucket/my-bucket/99-course.txt

- **Bucket names must be globally unique - no two AWS accounts anywhere can share the same name!**

Tip: *Naming rules trip up a lot of beginners - and a lot of exam questions.*

Discussion: A Real-World S3 Data Leak



What happened:

- In 2017, a data analytics firm left a database of about 198 million US voter records sitting in a publicly accessible S3 bucket
- The bucket had no password and no bucket policy restricting access - it stayed exposed for roughly two weeks before anyone noticed

Discuss:

- What single setting could have prevented this?
- Under the Shared Responsibility Model, whose fault was this - AWS's or the customer's?
- If you inherited this AWS account today, what would you check first?

The bigger picture:

- Public S3 exposures are still one of the most common cloud security incidents, and almost always come down to misconfiguration, not an AWS failure

S3 Security - User-Based vs Resource-Based



User-Based access:

- Controlled through IAM Policies attached to a specific IAM user, group, or role
- Defines which S3 API actions that identity is allowed to perform

Resource-Based access:

- Controlled through policies attached directly to the S3 resource itself
- Includes Bucket Policies and Access Control Lists (ACLs)

How access is decided:

- A user can access an object only if their IAM permissions or the resource policy allows it
- And there's no explicit Deny anywhere in the picture

Tip: *User-based asks "what can this person do?" - resource-based asks "who can touch this bucket?"*

S3 SECURITY:

USER-BASED vs RESOURCE-BASED

TekBay ACADEMY



User-Based Policies

Attached to Users, Groups, or Roles

- IAM Policies
- Controls what actions the user can perform

VS



Resource-Based Policies

Attached to Buckets or Objects

- Bucket Policies
- Controls who can access the resource



Alice can s3:GetObject on "my-bucket/**"



Allow "arn:aws:s3:::123456789012:user/Alice" to "GetObject"

S3 Bucket Policies



Definition:

- A bucket policy is a resource-based policy, written in JSON, that applies to an entire S3 bucket

What it can control:

- Who can access the bucket - specific IAM users, roles, or even other AWS accounts
- What actions they can perform - e.g., s3:GetObject, s3:PutObject, s3:DeleteObject
- Conditions such as IP address restrictions

Common uses:

- Allowing or denying public access to a bucket
- Granting cross-account access without creating IAM users in your account

---

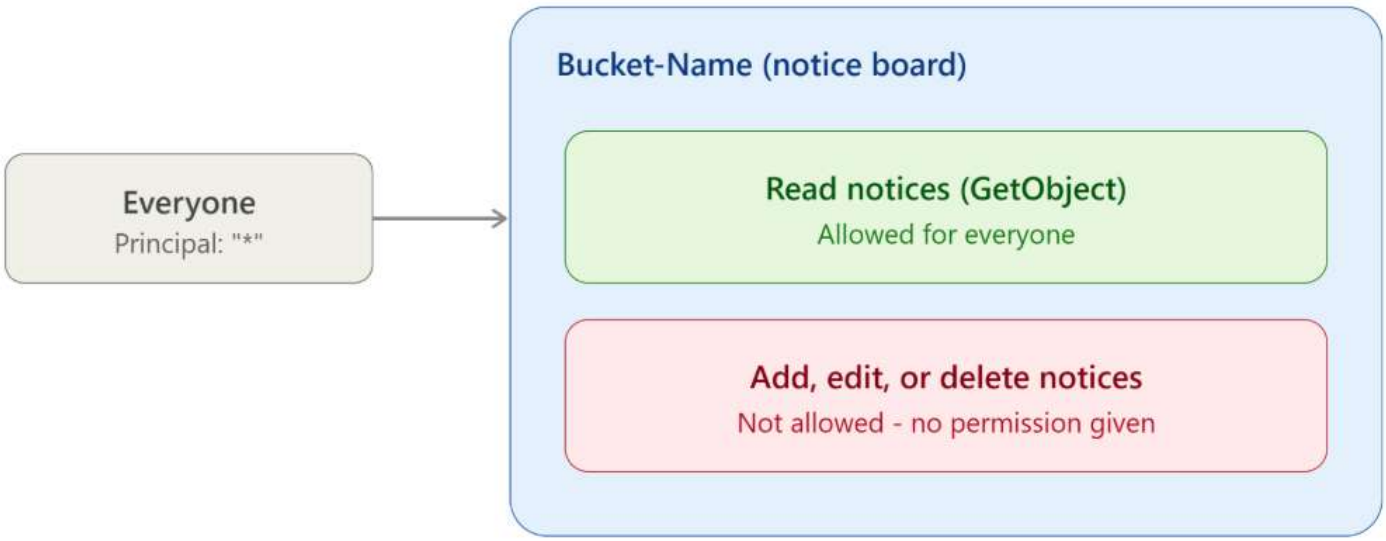
Tip: *A bucket policy lives with the bucket - it travels with the resource, not with any one user.*

S3 Bucket Policies




```
{
  "Version": "2012-10-17",                    // "Rulebook edition" — just says which version of AWS's rule-writing format we're using
  "Statement": [
    {
      "Sid": "PublicReadGetObject",           // Nickname for this rule: "Anyone can read the notice board"
      "Effect": "Allow",                      // We are GIVING permission (not blocking it)
      "Principal": "*",                       // WHO: Everyone — any student, teacher, or visitor walking past
      "Action": [
        "s3:GetObject"                        // WHAT they can do: only LOOK/READ the notice - not edit, not remove, not add new ones
      ],
      "Resource": [
        "arn:aws:s3:::Bucket-Name/*"          // WHERE: any notice pinned on THIS specific board (the "Bucket-Name" board)
      ]
    }
  ]
}
```

S3 Bucket Policies



Spot the Mistake: Bucket Policy



A team wants their app server to read files from a bucket, so they write this policy:

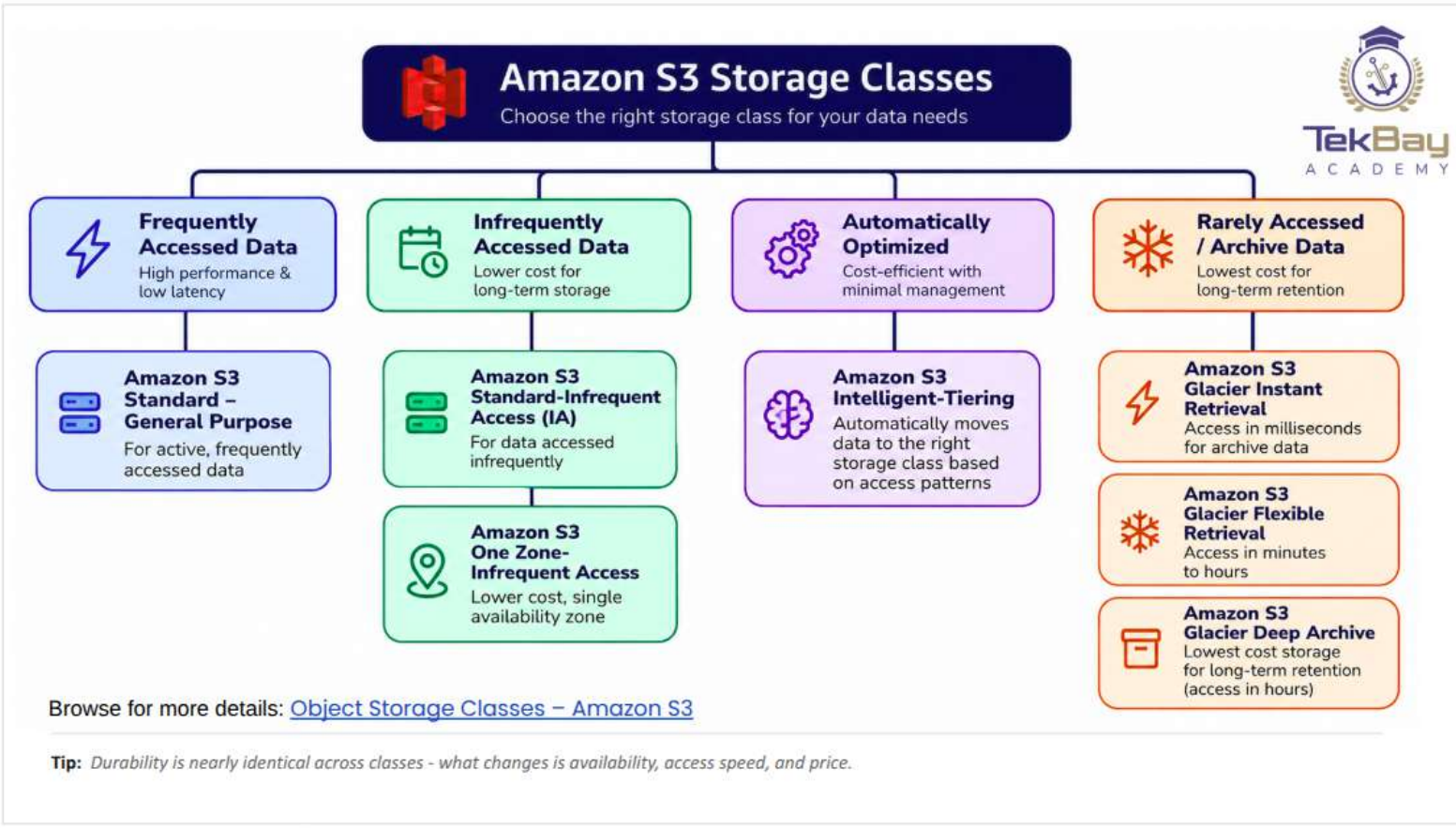
Spot the mistake...

```
"Effect": "Allow"

"Principal": "*"

"Action": "s3:GetObject"

"Resource": "arn:aws:s3:::company-app-data/*"
```



Browse for more details: [Object Storage Classes – Amazon S3]

Tip: *Durability is nearly identical across classes - what changes is availability, access speed, and price.*

Storage Classes: Standard & Infrequent Access



S3 Standard (General Purpose):

- 99.99% availability, low latency, high throughput
- Best for frequently accessed data - big data analytics, mobile apps, gaming, websites

S3 Standard-Infrequent Access (Standard-IA):

- 99.9% availability, lower storage cost than Standard
- Best for backups and disaster recovery - data you need quickly, but rarely

S3 One Zone-Infrequent Access:

- Stores data in only one Availability Zone - lower cost, lower resilience
- Best for secondary backups or easily re-creatable data

Tip: *Infrequent Access classes trade a little resilience and a retrieval fee for a lower storage price.*

Storage Classes: Glacier & Intelligent-Tiering



S3 Glacier (for long-term archiving):

- ❖ Very low storage cost, but you pay a retrieval fee to get data back
- **Glacier Instant Retrieval** – Offers millisecond access to archived data, making it ideal for data you access infrequently but need instantly, like once a quarter. It costs more than other Glacier tiers but saves you from retrieval delays.
- **Glacier Flexible Retrieval** – Retrieval takes minutes to hours, suited for archives that aren't time-sensitive. It's cheaper than Instant Retrieval and works well for backups or disaster recovery data you rarely need urgently.
- **Glacier Deep Archive** – This is the cheapest storage option, but retrieval takes 12–48 hours. It's built for long-term compliance or regulatory storage where data is almost never accessed but must be retained for years.

S3 Intelligent-Tiering:

- Automatically moves objects between tiers based on how often they're accessed
- No retrieval fees, just a small monthly monitoring fee
- Ideal when access patterns are unpredictable

Tip: *When you're not sure how often data will be accessed, Intelligent-Tiering removes the guesswork.*

Choosing the Right Storage Class



Ask yourself:

i. How often will this data be accessed?
ii. How quickly do I need to retrieve it if needed?
iii. Can I tolerate losing data if a single Availability Zone fails?
iv. Is this data required for compliance or long-term retention?

Quick guide:

- Frequently used → S3 Standard
- Infrequent but urgent → Standard-IA
- Infrequent and non-critical → One Zone-IA
- Unknown or changing access patterns → Intelligent-Tiering
- Rarely accessed archives → Glacier (pick based on retrieval speed needed)

Tip: *"Which storage class fits this data?" is one of the most common S3 exam scenarios.*

Quick Check: Pick the Right Storage Class



Scenario 1:

•A mobile app's user-uploaded photos, viewed constantly right after upload

Scenario 2:

•Financial records your company must retain for 7 years but almost never opens

Scenario 3:

•A dataset with completely unpredictable access - sometimes daily, sometimes untouched for months

S3 Lifecycle Policies



Definition:

A Lifecycle policy is a set of rules that automatically transitions or deletes objects as they age

Why it matters:

- Without automation, someone has to manually move old objects to cheaper storage or delete them
- Rules apply at the bucket level, and can target an entire bucket or just a prefix or tag

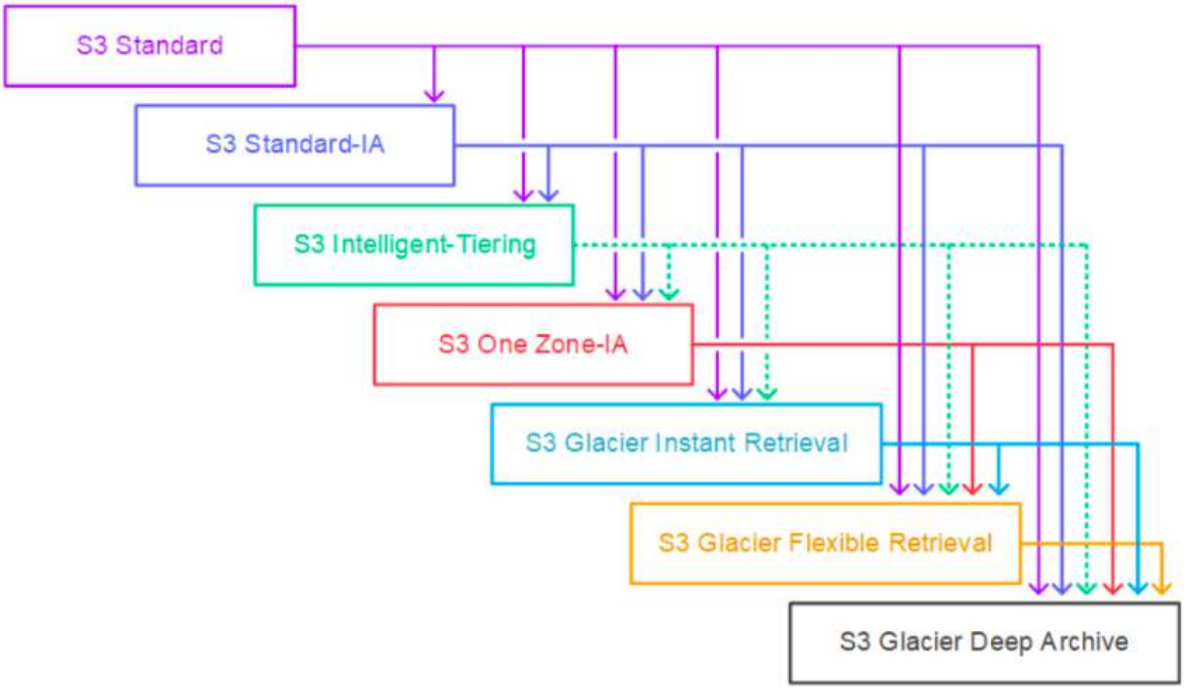
Two types of actions:

- Transition actions - move objects to a cheaper storage class after a set number of days
- Expiration actions - permanently delete objects after a set number of days

A typical rule might look like:

1) Standard for the first 30 days, while access is frequent
2) standard-IA after 30 days, once access slows down
3) Glacier Flexible Retrieval after 90 days, for long-term archiving
4) Delete after 365 days, once the data is no longer needed

S3 Lifecycle Rules



Key Takeaways:

- **Before we move on, let's recap what we covered yesterday:**
  - Amazon S3 is AWS's object storage service, storing data as objects inside buckets
  - S3 buckets must follow strict global naming rules
  - S3 security is split between user-based (IAM policies) and resource-based (bucket policies) access
  - Bucket policies are JSON documents that control who can access a bucket and what they can do
  - S3 offers multiple storage classes, from Standard to Glacier Deep Archive, based on access frequency



End of Day 3

Questions?